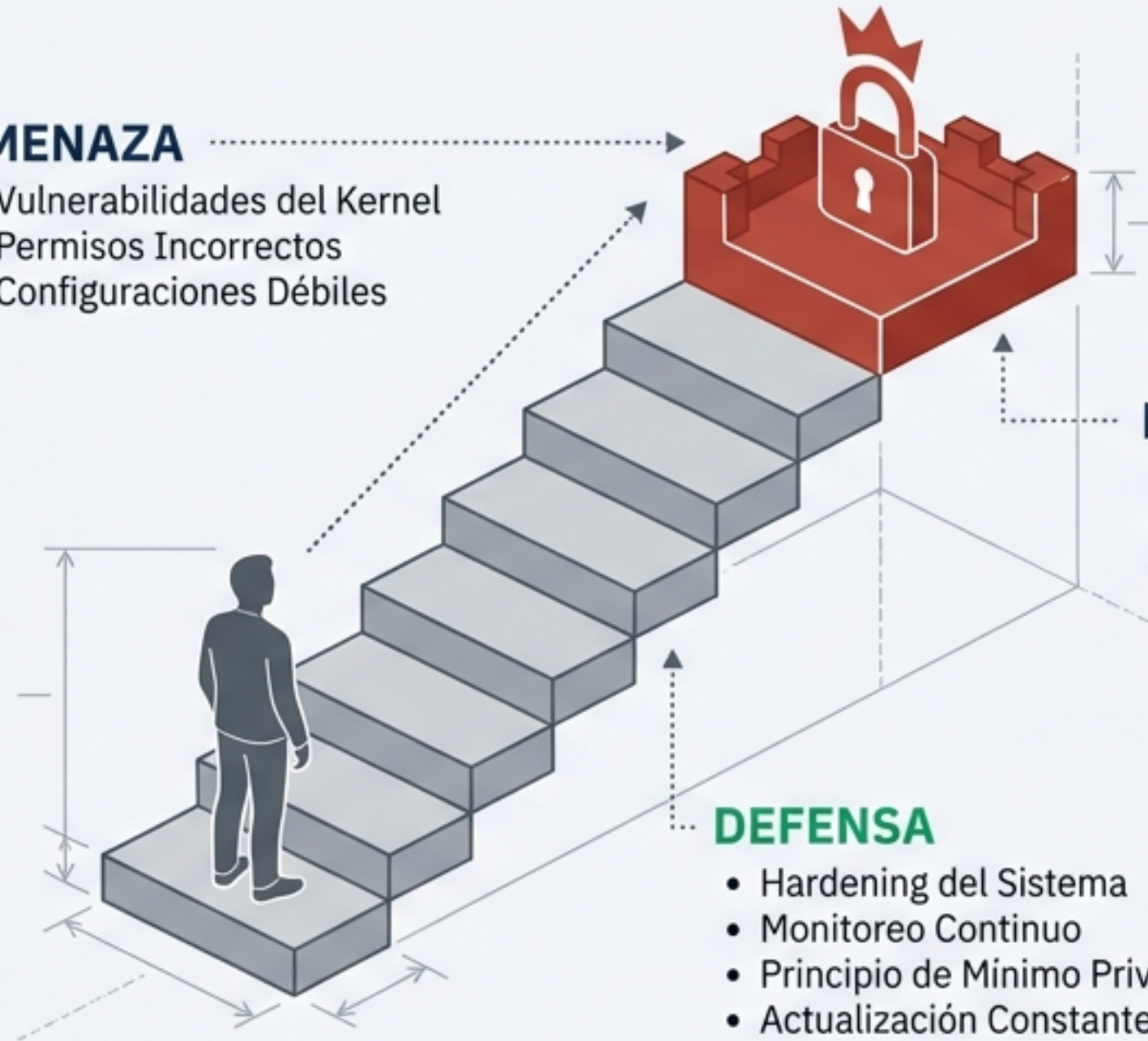


Escalada de Privilegios en Linux

El Camino a Root: Amenaza, Mecánica y Defensa

AMENAZA

- Vulnerabilidades del Kernel
- Permisos Incorrectos
- Configuraciones Débiles



MECÁNICA

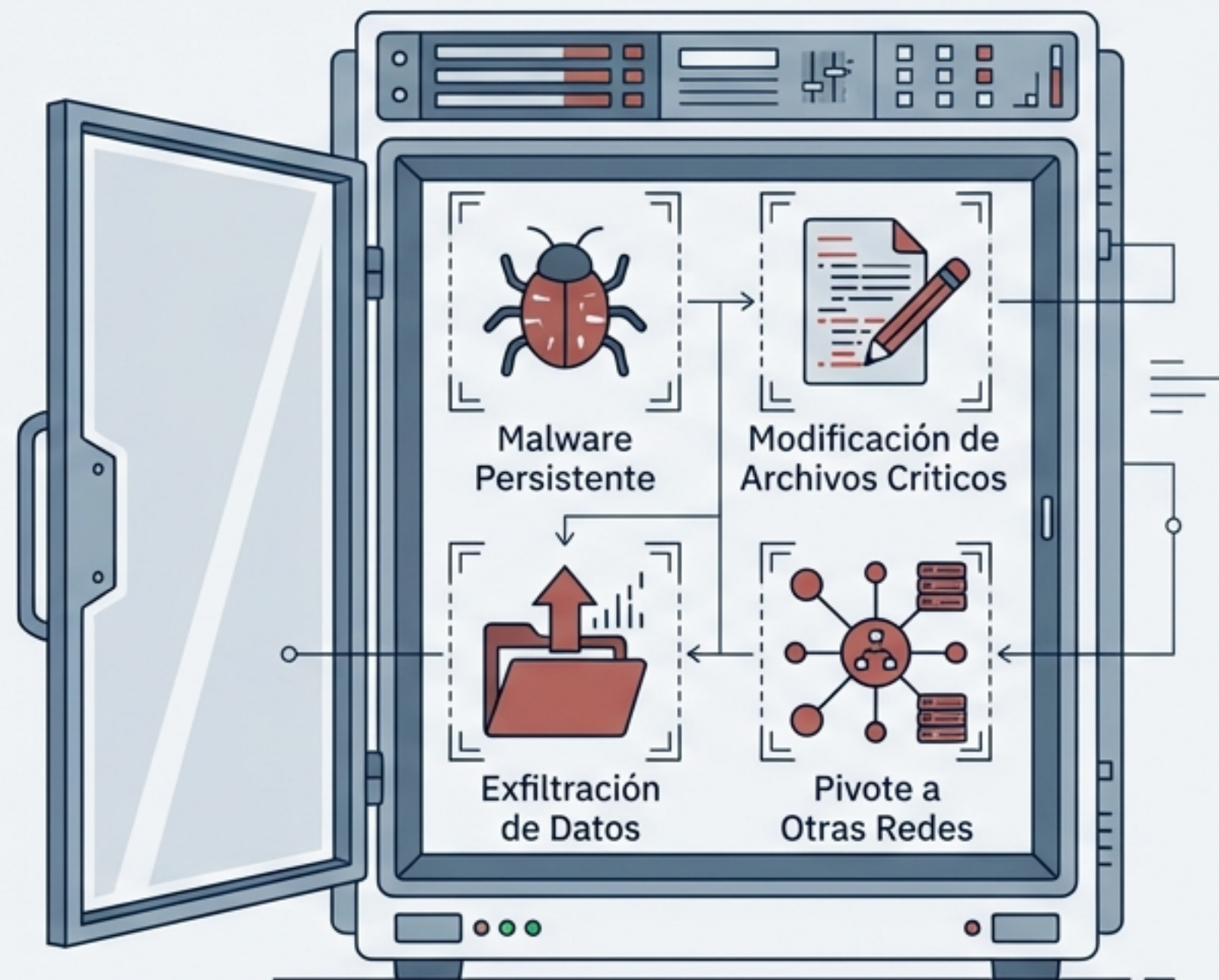
- Explotación de SUID
- Buffer Overflows
- Técnicas de Inyección

DEFENSA

- Hardening del Sistema
- Monitoreo Continuo
- Principio de Mínimo Privilegio
- Actualización Constante

El Objetivo Final: Acceso Root

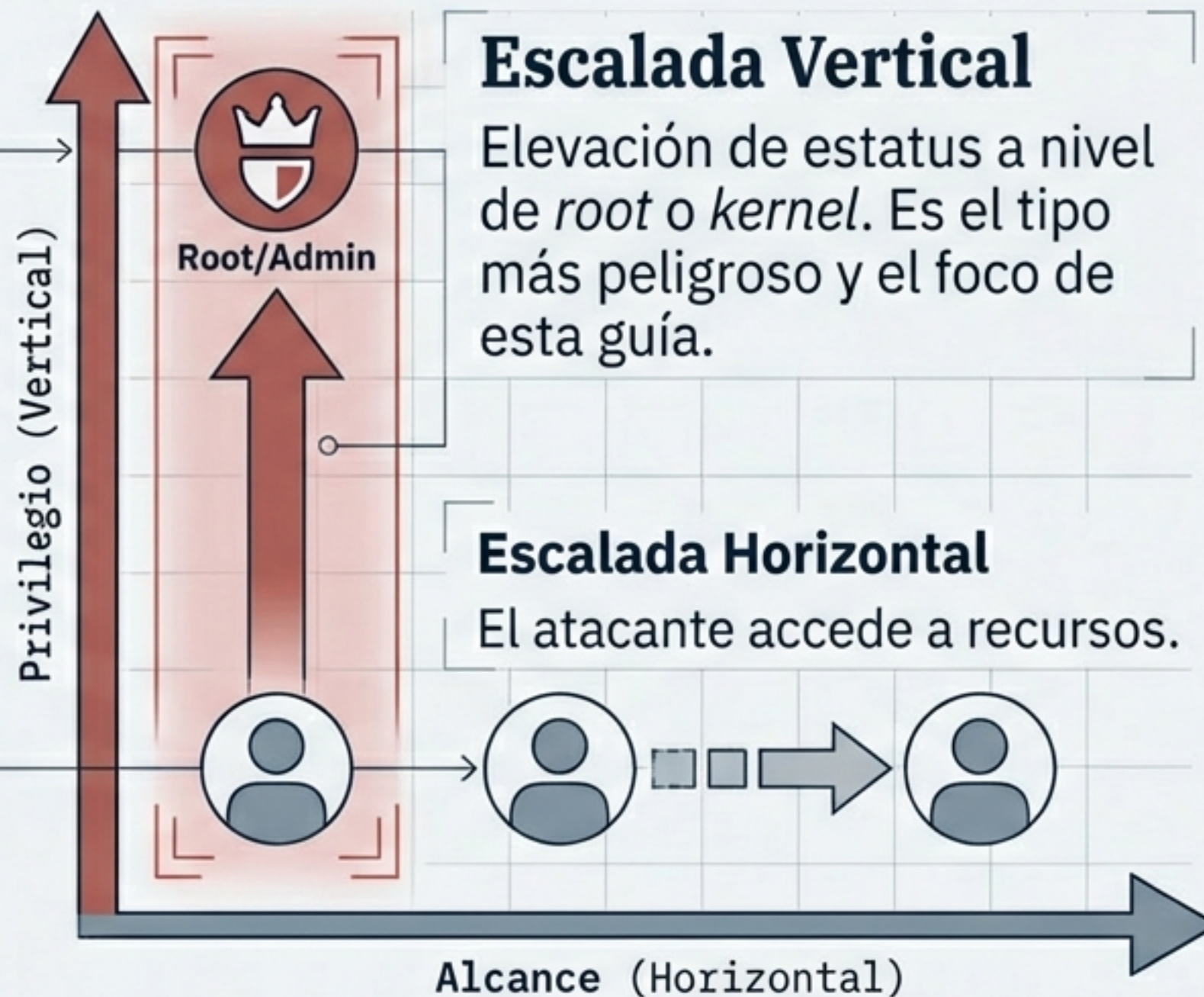
La **escalada de privilegios** es el puente que cruza un atacante desde una cuenta de bajos permisos hasta el control absoluto del sistema ('root').



Direcciones del Ataque: Horizontal vs. Vertical

Escalada Horizontal

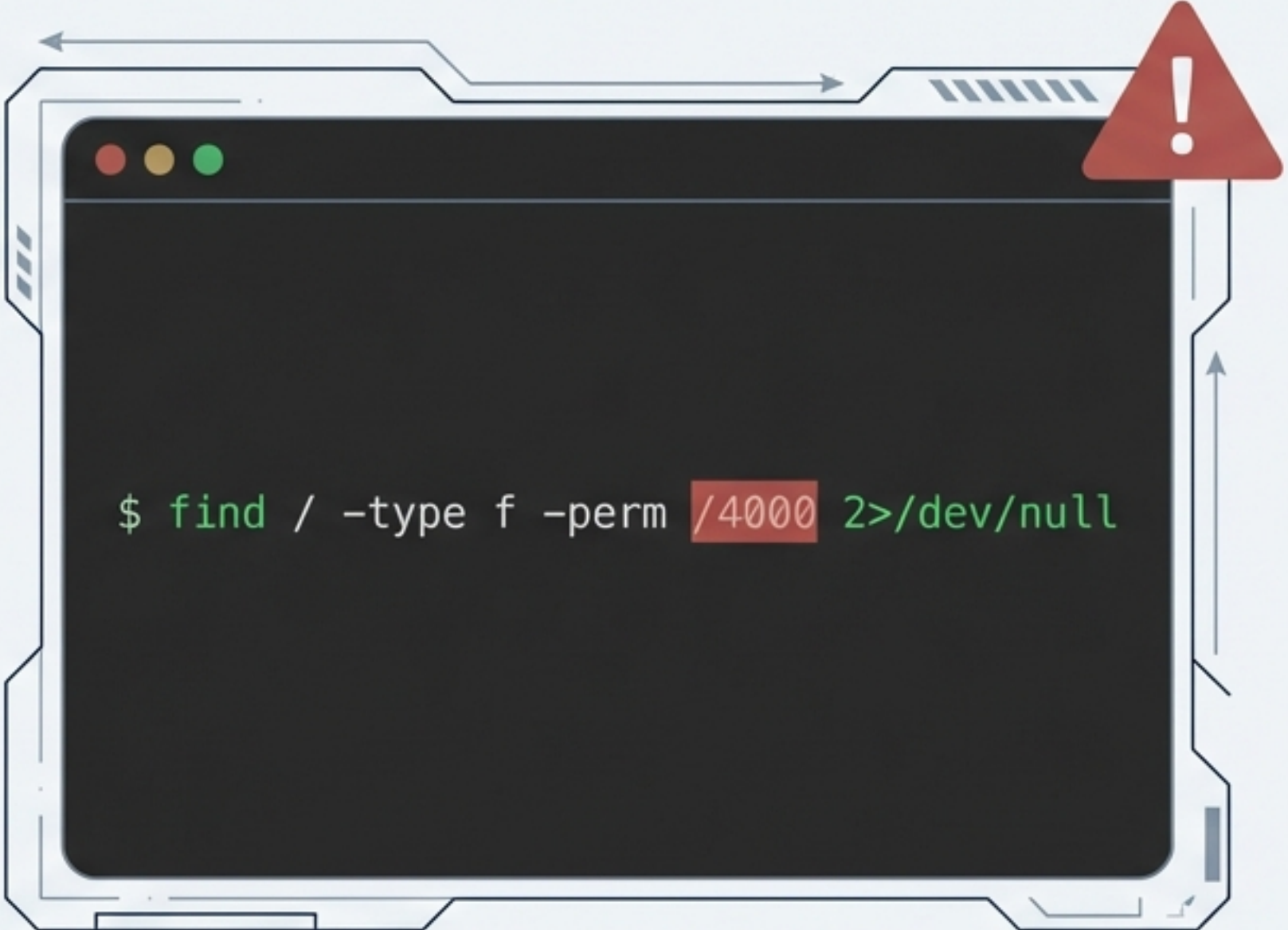
El atacante accede a recursos de *otro usuario regular*. Aumenta el alcance, pero no el nivel de permiso.



Vector A: El Error Clásico (SUID/SGID)

SUID (Set User ID): Un bit que permite ejecutar un binario con los permisos de su *dueño* (usualmente root) en lugar del usuario que lo ejecuta.

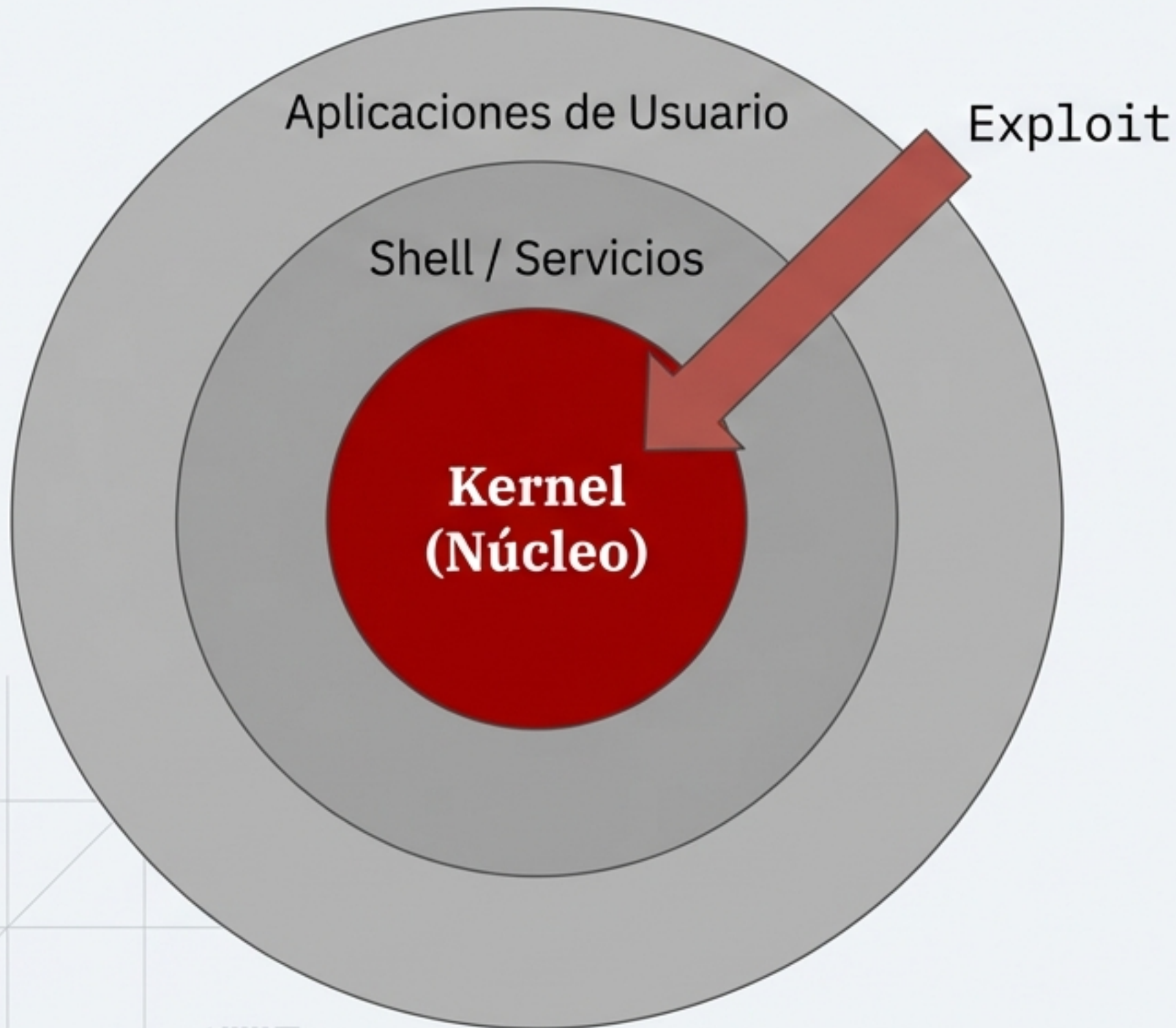
El Exploit: Si comandos como 'find', 'vim', 'vim', o 'nmap' tienen SUID activo, un usuario mortal puede usarlos para ejecutar comandos de sistema como administrador.



```
$ find / -type f -perm /4000 2>/dev/null
```

Comando para listar todos los archivos con bit SUID activo.

Vector B: Fallas en el Corazón (Kernel y Drivers)



Vulnerabilidades Críticas: Bugs en el código fuente del Núcleo de Linux o sus controladores.

Impacto: Ejecución de código arbitrario con privilegios de kernel (equivalentes a root).

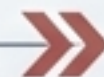
Nota: Difíciles de mitigar sin parches del proveedor.

Vector C: La Puerta Mal Cerrada (Sudo)

El archivo /etc/sudoers define quién puede actuar como root. Una configuración laxa es fatal.



Riesgo de Shell Escape: Permitir 'sudo' en programas como 'vi', 'less' o 'awk' otorga acceso root instantáneo.



Caso de Estudio

Permiso Inseguro:

Usuario puede ejecutar /usr/bin/find.

Comando de Ataque:

```
$ sudo find / -exec /bin/sh \;
```

Resultado:

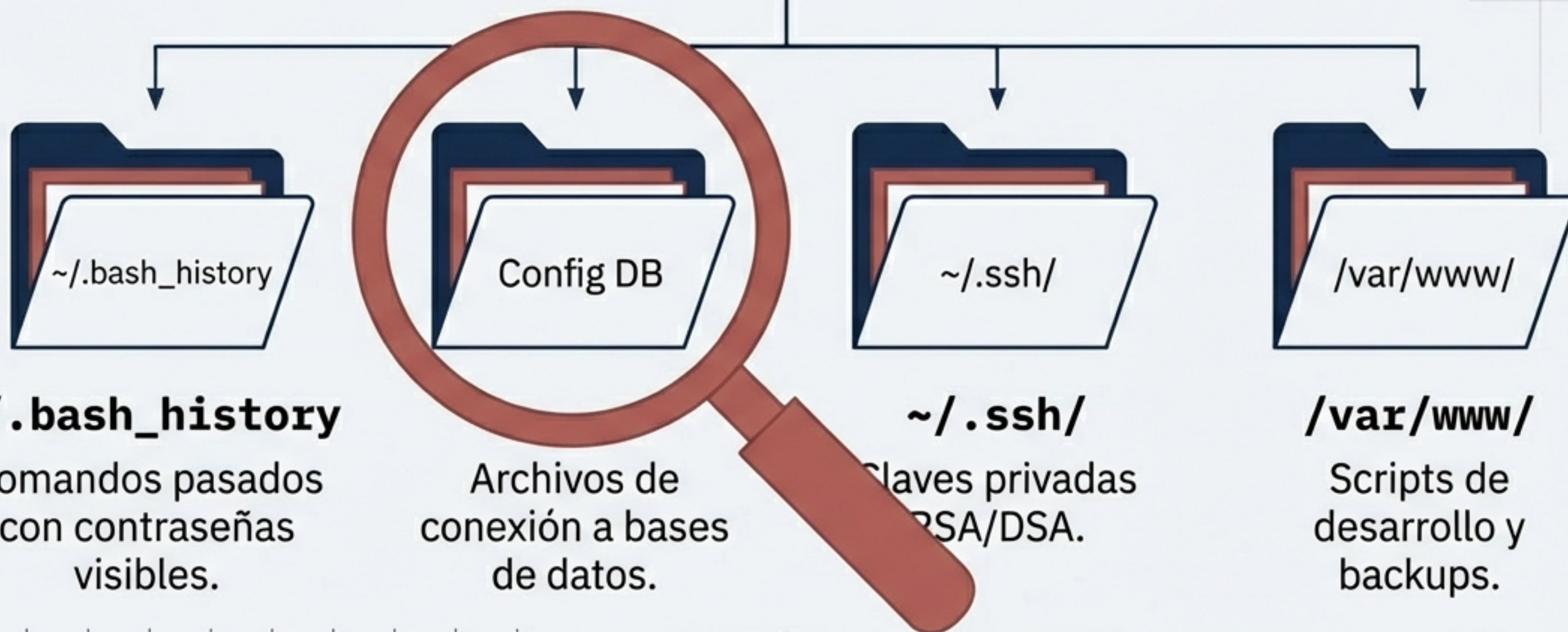
root shell access granted !



Danger

Vector D: Secretos a la Vista (Credenciales Hardcoded)

El error humano deja huellas. Ocurre cuando claves o contraseñas se dejan en texto plano ('hardcoded') en scripts o archivos olvidados.



Danger

Estrategia de Defensa en Profundidad

Cinco Pilares para Fortalecer el Sistema

1. Actualización

El primer muro contra fallas de software.

2. Permisos (PoLP)

Eliminar privilegios innecesarios.

3. Configuración Sudo

Especificidad estricta.

3. Configuración Sudo

Especificidad estricta.

4. Higiene del Historial

Ocultar los pasos administrativos.

5. Hardening y Monitoreo

Endurecimiento y vigilancia.



Danger

Pilar 1: Actualización y Parcheo

La defensa más crítica.

Mantener el Kernel y el software principal siempre al día mitiga directamente las vulnerabilidades de código (Vector B).

Acción: Instalar parches de seguridad inmediatamente tras su publicación.

(Debian/Ubuntu)

```
$ apt update && apt upgrade
```

(RHEL/Fedora)

```
$ dnf upgrade
```



Danger

Pilar 2: Gestión de Permisos (PoLP)

Principio de Mínimo Privilegio. Los usuarios y aplicaciones deben tener *solo* los permisos estrictamente necesarios.

Best Practice: Gestión de SUID

Inspeccionar regularmente binarios SUID/SGID y eliminar el bit de cualquier comando que no lo requiera absolutamente.

```
$ sudo chmod u-s /ruta/al/binario
```

Comando para eliminar el bit SUID

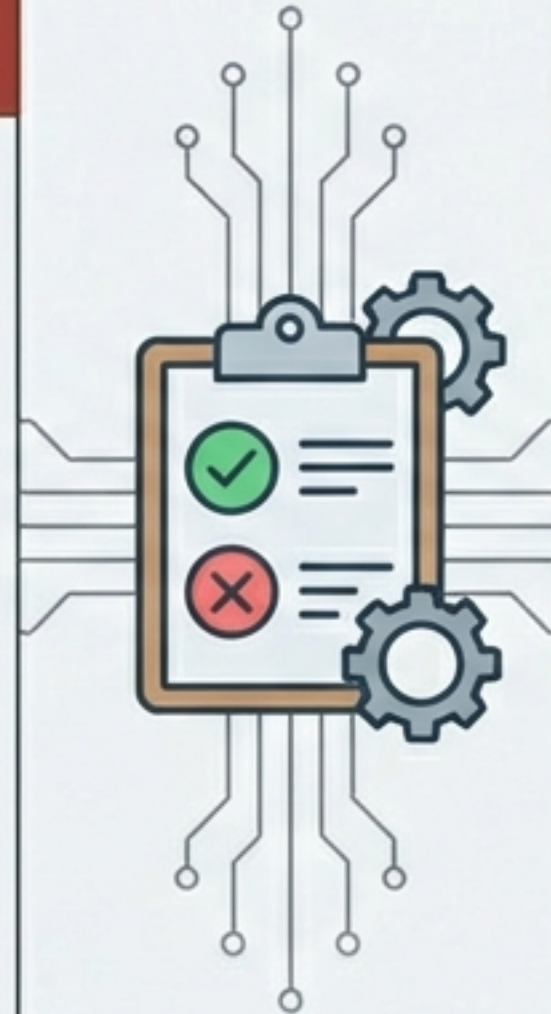


Danger

Pilar 3: Configuración Inteligente de Sudo

EVITAR

- Nunca usar el comodín **ALL** para usuarios regulares.
- No dar permisos 'sudo' a binarios con escapes a shell (vim, find, less).



HACER

- **Especificidad:** Configurar el acceso comando por comando.
- **Alternativas:** Usar 'sudoedit' en lugar de 'sudo vim' para editar archivos.



Danger

Pilar 4: Higiene del Historial (.bash_history)

El historial revela contraseñas y el mapa de la red. Configurar las variables de entorno es vital.

Variable	Valor Sugerido	Descripción
HISTSIZE	2000	Memoria sesión actual
HISTFILESIZE	4000	Líneas en disco

Truco Pro: El Espacio Invisible

Configuración: 'export HISTCONTROL=ignorespace'

```
$ ssh user@host
```

Este espacio evita que el comando se guarde.



Danger

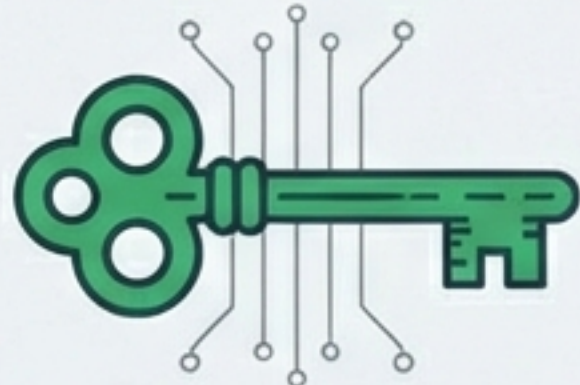
Pilar 5: Endurecimiento del Sistema (Hardening)

Control de Acceso Obligatorio (MAC)



Habilitar **SELinux** o **AppArmor**. Estos sistemas restringen lo que los procesos pueden hacer, limitando el daño incluso si el atacante es root.

Políticas de Credenciales



Implementar contraseñas fuertes y asegurar que nunca se almacenen en texto plano.

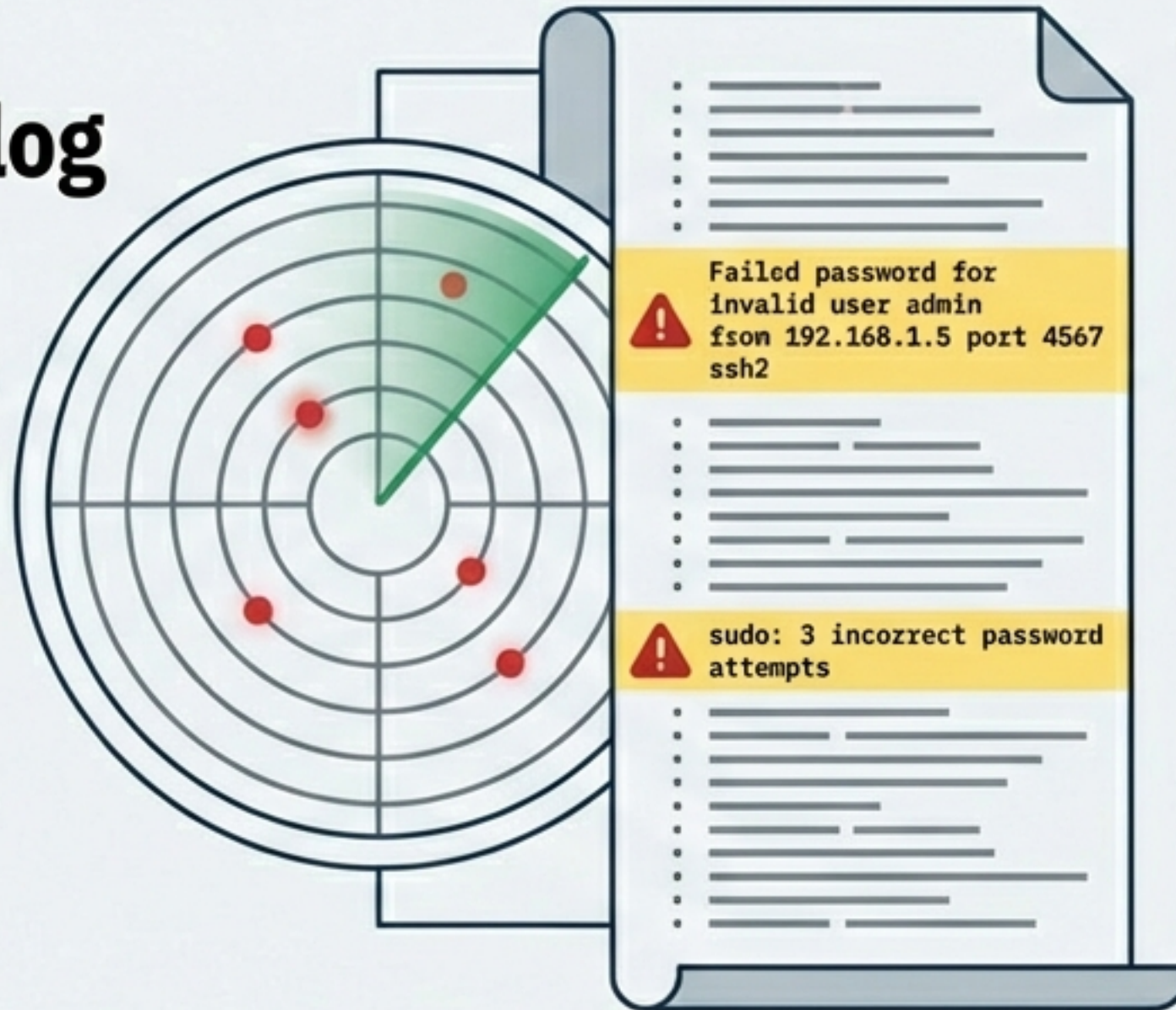


Danger

Vigilancia Constante: Monitoreo y Logs

Auditoría de Registros

- Revisar **/var/log/auth.log** o **journalctl**.
- Buscar: Intentos fallidos de “su”/“sudo” o actividad inusual en SUID.



Integridad de Archivos

- Herramientas: **Tripwire** o **AIDE**.
- Función: Alertan si un binario crítico ha sido modificado.



Defense



Danger

Resumen Ejecutivo: La Seguridad es un Proceso

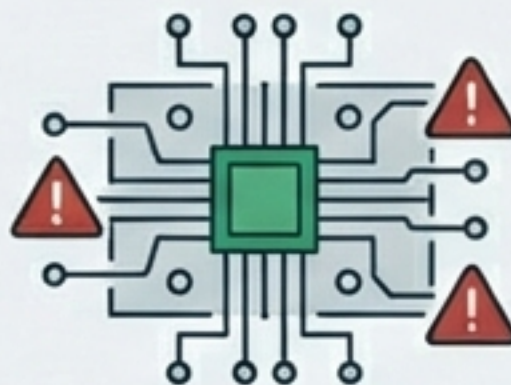
La Amenaza

La escalada vertical busca el control total (Root).



Los Vectores

SUID mal configurado, Kernels desactualizados, Sudo permisivo y secretos expuestos.



La Defensa

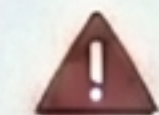
Estrategia en profundidad: Actualizar, Restringir (PoLP), Configurar y Monitorear.



Un sistema seguro no es el que nunca es atacado, sino el que está diseñado para resistir y limitar el avance.



Defense



Danger